

INFORME DE SEGURIDAD INTEGRAL

Arquitectura de Seguridad Cloud (Azure) e IoT para TrailConnect

1. Introducción y Marco de Seguridad

La seguridad en el proyecto TrailConnect es un pilar crítico, dado que el sistema gestiona datos de geolocalización, información personal de corredores y alertas de emergencia en tiempo real (Botón SOS). Este documento define la estrategia de seguridad end-to-end, abarcando desde la capa física de los nodos IoT (ESP32), el transporte a través de LoRaWAN, hasta el despliegue en la infraestructura en la nube de Microsoft Azure.

Objetivo Principal: Garantizar la Confidencialidad, Integridad y Disponibilidad (Triada CIA) de los datos telemétricos, evitando interceptaciones, suplantación de identidades de dispositivos y ataques de denegación de servicio (DDoS).

2. Seguridad en la Capa IoT (Edge) y Transporte LoRaWAN

El primer vector de ataque se encuentra en el entorno físico de la montaña, donde los dispositivos están expuestos. Para mitigarlo, se aplican las siguientes medidas:

- **Cifrado AES-128 en LoRaWAN:** Cada paquete emitido por el ESP32 está doblemente cifrado. Se utiliza una clave de sesión de red (NwkSKey) para asegurar la integridad de la comunicación con el Gateway, y una clave de sesión de aplicación (AppSKey) que garantiza que el contenido (Payload) solo sea descifrable en el servidor final, evitando que el operador del Gateway lea los datos.
- **Prevención de Ataques de Replay:** El protocolo LoRaWAN implementa contadores de tramas (Frame Counters). Si el servidor recibe un paquete con un contador inferior o repetido, lo descarta automáticamente, impidiendo que un atacante capture un mensaje de SOS y lo reenvíe posteriormente.
- **Protección de Hardware:** Desactivación de los puertos JTAG de los microcontroladores ESP32 para evitar el volcado del firmware y la extracción de claves criptográficas por manipulación física.

3. Arquitectura de Seguridad en Microsoft Azure

Una vez que los datos alcanzan la nube, Azure centraliza la gestión de identidades, el cifrado y la defensa perimetral del sistema.

3.1. Autenticación y Autorización (Azure IoT Hub)

El punto de entrada a la nube es Azure IoT Hub. No se permite la conexión de ningún dispositivo no autorizado:

- **Certificados X.509:** Cada Gateway y servidor de red LoRa se autentica contra Azure mediante certificados X.509, garantizando una confianza mutua.
- **Tokens SAS (Shared Access Signature):** Para servicios internos, se generan tokens con permisos de privilegio mínimo y caducidad temporal estricta.

3.2. Cifrado de Datos en Reposo (Bases de Datos)

Aplicando el modelo de persistencia políglota definido anteriormente, se asegura el almacenamiento:

- **Transparent Data Encryption (TDE) en PostgreSQL:** La base de datos relacional cifra los archivos de datos, registros y copias de seguridad en tiempo real. Esto asegura que la información personal de los usuarios y las clasificaciones sean ilegibles si se extraen los discos físicos.
- **Cifrado a Nivel de Volumen en MongoDB:** Los documentos no estructurados (logs de IoT, telemetría bruta) se cifran en disco utilizando el sistema de gestión de claves de Azure (Azure Key Vault).

3.3. Seguridad en la Capa de Presentación (Frontend y API)

- **Cifrado en Tránsito (TLS 1.2/1.3):** Toda comunicación entre el frontend estático (alojado en GitHub Pages/Vercel) y las APIs de Azure se realiza obligatoriamente mediante HTTPS, protegiendo los datos contra ataques Man-in-the-Middle (MitM).
- **Control de Acceso Basado en Roles (RBAC):** Se implementa Azure Entra ID (anteriormente Active Directory) para gestionar el acceso al panel de administración. Los roles están estrictamente divididos: un "Organizador" no tiene permisos para modificar la infraestructura del sistema, labor reservada al "SysAdmin".

4. Monitorización y Respuesta a Incidentes

Para asegurar una supervisión proactiva, TrailConnect integrará **Microsoft Defender for IoT** y **Azure Monitor**. Estas herramientas analizan el comportamiento del tráfico mediante Inteligencia Artificial. Si se detecta una anomalía, como un nodo enviando alertas SOS a una frecuencia imposible o un intento de acceso masivo a la base de datos (DDoS), el sistema aislará automáticamente el nodo comprometido y emitirá una alerta al equipo de administración.

5. Conclusión

La arquitectura de seguridad de TrailConnect se fundamenta en un modelo de "Zero Trust" (Confianza Cero). Ningún dispositivo o usuario tiene acceso por defecto. Gracias a la combinación del cifrado inherente de LoRaWAN y las sólidas políticas de aislamiento, cifrado y monitorización

de Azure, el sistema está preparado para cumplir con normativas estrictas de protección de datos (RGPD) y garantizar la seguridad vital de los participantes.